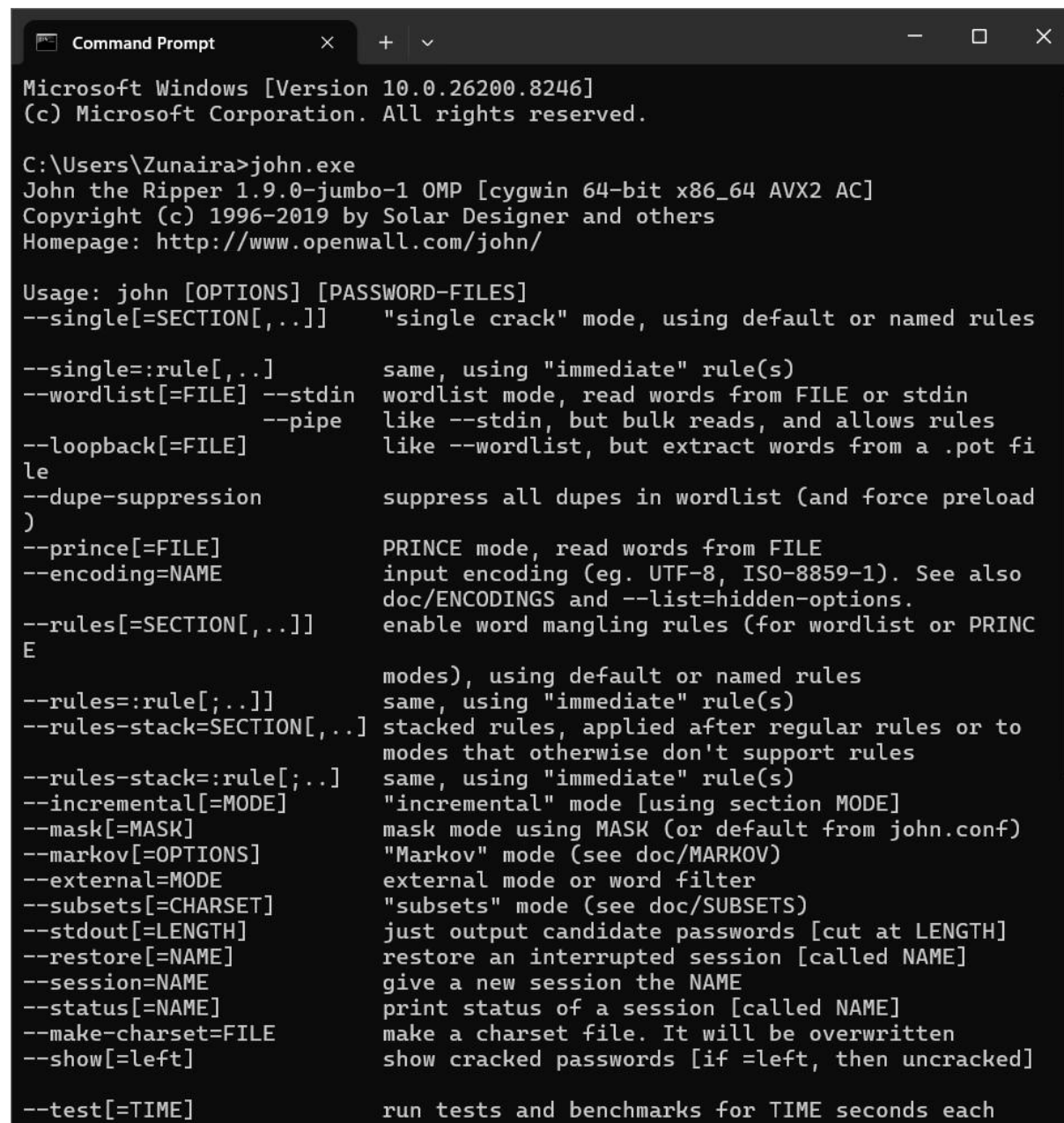


Task 1: Installation & Configuration

1a.



```
Microsoft Windows [Version 10.0.26200.8246]
(c) Microsoft Corporation. All rights reserved.

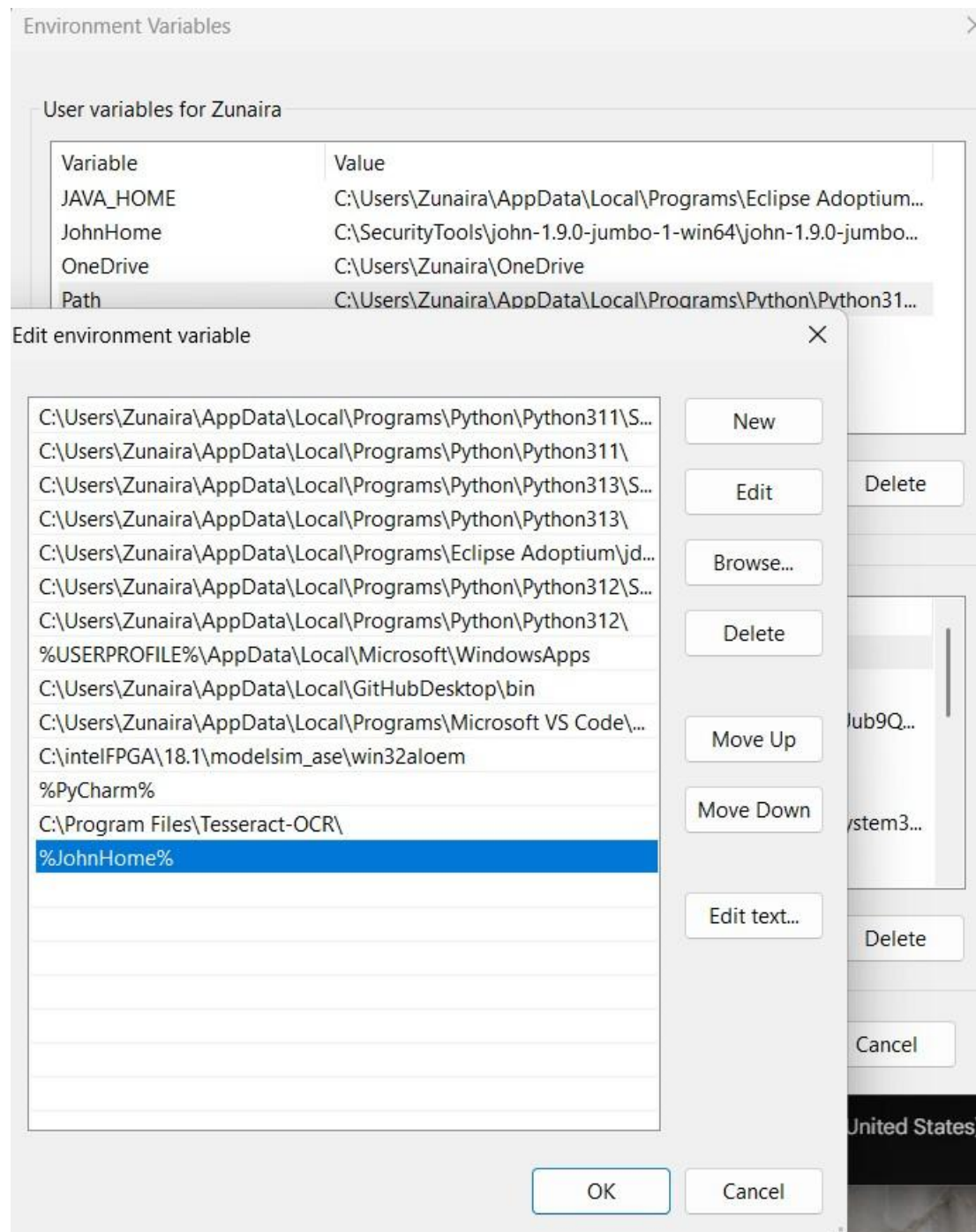
C:\Users\Zunaira>john.exe
John the Ripper 1.9.0-jumbo-1 OMP [cygwin 64-bit x86_64 AVX2 AC]
Copyright (c) 1996-2019 by Solar Designer and others
Homepage: http://www.openwall.com/john/

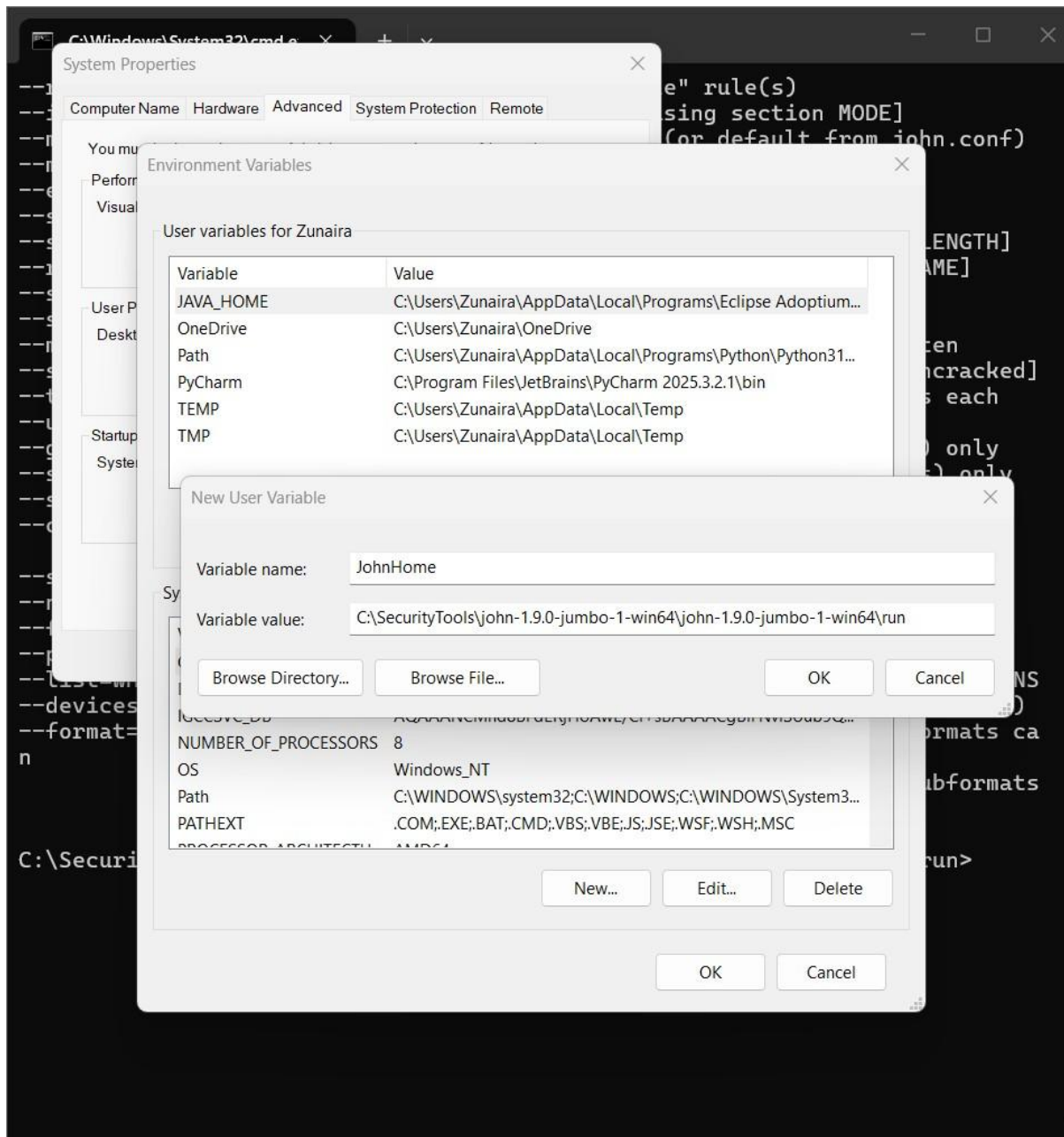
Usage: john [OPTIONS] [PASSWORD-FILES]
--single[=SECTION[,..]]    "single crack" mode, using default or named rules

--single=:rule[,..]        same, using "immediate" rule(s)
--wordlist[=FILE] --stdin  wordlist mode, read words from FILE or stdin
                        --pipe like --stdin, but bulk reads, and allows rules
--loopback[=FILE]         like --wordlist, but extract words from a .pot fi
le
--dupe-suppression        suppress all dupes in wordlist (and force preload
)
--prince[=FILE]           PRINCE mode, read words from FILE
--encoding=NAME           input encoding (eg. UTF-8, ISO-8859-1). See also
doc/ENCODINGS and --list=hidden-options.
--rules[=SECTION[,..]]    enable word mangling rules (for wordlist or PRINC
E
                           modes), using default or named rules
--rules=:rule[;..]        same, using "immediate" rule(s)
--rules-stack=SECTION[,..] stacked rules, applied after regular rules or to
                           modes that otherwise don't support rules
--rules-stack=:rule[;..]  same, using "immediate" rule(s)
--incremental[=MODE]      "incremental" mode [using section MODE]
--mask[=MASK]             mask mode using MASK (or default from john.conf)
--markov[=OPTIONS]        "Markov" mode (see doc/MARKOV)
--external=MODE           external mode or word filter
--subsets[=CHARSET]       "subsets" mode (see doc/SUBSETS)
--stdout[=LENGTH]         just output candidate passwords [cut at LENGTH]
--restore[=NAME]          restore an interrupted session [called NAME]
--session=NAME            give a new session the NAME
--status[=NAME]           print status of a session [called NAME]
--make-charset=FILE       make a charset file. It will be overwritten
--show[=left]             show cracked passwords [if =left, then uncracked]

--test[=TIME]             run tests and benchmarks for TIME seconds each
```

1b.





1c.

Without PATH setup, john.exe only works if my Command Prompt is open inside the run folder. If I'm anywhere else, Windows simply can't find it.

By adding it to PATH, we tell Windows "no matter where I am, you can find john.exe here." So when I open Command Prompt from any folder and just type john.exe. It works instantly without navigating anywhere first.

The practical problem it solves: It saves us from having to manually navigate to the installation folder every single time I want to use the tool.

.....

Task 2: Hash Cracking — Dictionary Attack

2a.

`john --wordlist=rockyou.txt --format=md5crypt lab_hashes.txt`

```
C:\Windows\System32\cmd.e x + v
Microsoft Windows [Version 10.0.26200.8246]
(c) Microsoft Corporation. All rights reserved.

C:\SecurityTools\john-1.9.0-jumbo-1-win64\john-1.9.0-jumbo-1-win64\run>john
--wordlist=rockyou.txt --format=md5crypt lab_hashes.txt
Using default input encoding: UTF-8
Loaded 5 password hashes with 5 different salts (md5crypt, crypt(3) $1$ (and
variants) [MD5 256/256 AVX2 8x3])
Will run 8 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
0g 0:00:00:02 15.62% (ETA: 10:12:43) 0g/s 63250p/s 316563c/s 316563C/s 24009
1..240782
InfoSec2024      (lecturer)
password123      (student01)
2g 0:00:00:15 DONE (2026-04-24 10:12) 0.1285g/s 64590p/s 322815c/s 322815C/s
itu24037..zxcvbn
Use the "--show" option to display all of the cracked passwords reliably
Session completed

C:\SecurityTools\john-1.9.0-jumbo-1-win64\john-1.9.0-jumbo-1-win64\run>
```

2b.

`john --wordlist=rockyou.txt --rules --format=md5crypt lab_hashes.txt`

```
C:\SecurityTools\john-1.9.0-jumbo-1-win64\john-1.9.0-jumbo-1-win64\run>john
--wordlist=rockyou.txt --rules --format=md5crypt lab_hashes.txt
Using default input encoding: UTF-8
Loaded 5 password hashes with 5 different salts (md5crypt, crypt(3) $1$ (and
variants) [MD5 256/256 AVX2 8x3])
Remaining 3 password hashes with 3 different salts
Will run 8 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
0g 0:00:00:02 0.46% (ETA: 10:21:39) 0g/s 98871p/s 296905c/s 296905C/s 334095
..334786
0g 0:00:00:14 DONE (2026-04-24 10:14) 0g/s 71484p/s 214454c/s 214454C/s Rizw
aned..Zxcvbnng
Session completed

C:\SecurityTools\john-1.9.0-jumbo-1-win64\john-1.9.0-jumbo-1-win64\run>
```


Zunaira Abdul Aziz
BSSE23058

What managing rules do is they transform each word in the wordlist automatically eg: turning summer into Summer, SUMMER, summer1, summ3r etc. This catches passwords that users slightly modified from common words.

2c.

john --show --format=md5crypt lab_hashes.txt

```
C:\SecurityTools\john-1.9.0-jumbo-1-win64\john-1.9.0-jumbo-1-win64\run>john
--show --format=md5crypt lab_hashes.txt
lecturer:InfoSec2024
student01:password123

2 password hashes cracked, 3 left

C:\SecurityTools\john-1.9.0-jumbo-1-win64\john-1.9.0-jumbo-1-win64\run>
```

Username Recovered Password

lecturer InfoSec2024

student01 password123

itadmin not cracked

labassist not cracked

dbadmin not cracked

2d.

No, only 2 out of 5 hashes were cracked. The remaining 3 (itadmin, labassist, dbadmin) were not found because their passwords likely:

- Are not common words found in rockyou.txt
- May contain random characters, symbols, or numbers that mangling rules couldn't predict
- Could be longer or more complex passwords that require brute force to crack

Task 3: Hash Cracking — Brute Force Attack

3a.

john --incremental:Digits --format=md5crypt challenge_hash.txt

I used the --incremental:Digits flag because we already know the PIN is numbers only (0–9). This restricts JtR to only try numeric combinations, meaning it only has 10,000 possible combinations (0000–9999) to go through, which is why it cracked it in just 2 seconds.

If we had used plain --incremental instead (which tries letters, numbers AND symbols), it would have taken much longer for no reason since we already knew it was digits only. Choosing the right character set makes the attack as fast and efficient as possible.

3b.

```
C:\Windows\System32\cmd.exe X + v
Microsoft Windows [Version 10.0.26200.8246]
(c) Microsoft Corporation. All rights reserved.

C:\SecurityTools\john-1.9.0-jumbo-1-win64\john-1.9.0-jumbo-1-win64\run>john --incremental:Digits --format=md5crypt challenge_hash.txt
Using default input encoding: UTF-8
Loaded 1 password hash (md5crypt, crypt(3) $1$ (and variants) [MD5 256/256 AVX2 8x3])
Will run 8 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
2019 (pinuser)
lg 0:00:00:02 DONE (2026-04-24 10:34) 0.4992g/s 95089p/s 95089c/s 95089C/s 1480..26258
Use the "--show" option to display all of the cracked passwords reliably
Session completed

C:\SecurityTools\john-1.9.0-jumbo-1-win64\john-1.9.0-jumbo-1-win64\run>h
```

Cracked PIN 2019

Username pinuser
Time Taken 2 seconds
Speed 95,089 guesses/second

3c.

	Dictionary Attack	Brute Force
Speed	Fast, only tries words from a list	Slow, tries every possible combination
Coverage	Only finds passwords that exist in the wordlist	Guaranteed to find ANY password eventually
Best for	Common, human-chosen passwords like password123	Short/unknown passwords like PINs
When to use	Always try this first, catches most weak passwords quickly	Last resort when dictionary attack fails

Task 4: Conceptual Questions

4a.

A password hash is a fixed-length string of characters produced by running a password through a one-way mathematical function. When you set a password, the system doesn't save the password itself, it saves this hash instead.

Operating systems store hashes instead of plaintext because if a hacker breaks into the system, they only find hashes, not actual passwords. They still have to crack them, which takes time and may fail entirely for strong passwords.

Risk of plaintext storage: If passwords were stored in plaintext and an attacker gained access, they would instantly have every single user's password with no effort, including passwords people reuse on other websites and apps, making the damage far worse.

4b.

A salt is a random string that is added to a password before it is hashed. Every user gets a unique salt, meaning even if two users have the exact same password, their hashes will look completely different.

Why it makes cracking harder: Without salting, an attacker could pre-compute hashes for millions of common passwords and instantly look up matches. With salting, this doesn't work, every hash is unique and must be cracked individually, multiplying the time and effort required significantly.

4c.

Password hashes on Linux are stored in `/etc/shadow`.

Correct permissions: `-rw-r-----` readable only by root and the shadow group, not by regular users.

Why misconfiguration is critical: If `/etc/shadow` is accidentally made readable by all users (wrong permissions), any user on the system can copy all the hashes and crack them offline at their own pace using a tool like John the Ripper. This was exactly what we practiced in this lab, once you have the hash file, cracking can happen anywhere, anytime, with no time limit.

4d.

1. Unpatched Software Running outdated software with known security flaws. For example, a web server still running Apache 2.4.29 has multiple published CVEs that were fixed in later versions, an attacker can look these up and exploit them directly.

2. Misconfiguration Security settings left at defaults or set up incorrectly. For example, a database server with port 3306 open to the entire internet instead of being restricted to internal network access only, allowing anyone to attempt a connection.

3. Code Flaws (Injection Attacks) Bugs in application code that allow attackers to inject malicious input. For example, a login form vulnerable to SQL injection where typing ' OR 1=1 -- bypasses authentication entirely and grants access without a valid password.

4e.

Following the vulnerability assessment lifecycle:

1. **Search the NVD** (nvd.nist.gov) for "Apache 2.4.29" to find all known CVEs associated with this version and their CVSS severity scores.
2. **Analyze the findings** check which vulnerabilities apply to this server's configuration and whether they are remotely exploitable.
3. **Rate the risk** using the CVSS score. Any score above 7.0 is High or Critical and needs urgent attention.
4. **Document the finding** in the report with evidence (the version number from the scan), the CVE IDs found, their impact, and proof that the version is outdated.

5. **Recommend remediation**, update Apache to the latest stable version immediately, as this directly eliminates all known CVEs for older versions.
 6. **Retest after patching** run the vulnerability scanner again to confirm the updated version is now running and the finding is resolved.
-

Task 5: Reflection & Ethics

5a.

I would not ignore this situation. First, I would inform the colleague that what they are doing is illegal regardless of their intention unauthorized access to computer systems violates laws such as the Computer Fraud and Abuse Act (CFAA) in the US, and similar cybercrime laws apply in Pakistan under the Prevention of Electronic Crimes Act (PECA) 2016. "Just testing security" is not a valid defense without written authorization from management.

I would then report the incident to my supervisor or the IT security team, because staying silent makes me complicit. Ethically, this aligns with the (ISC)² Code of Ethics, which requires security professionals to act lawfully, protect society, and be honest. Unauthorized testing, even with good intentions, can disrupt systems, expose data, and create serious legal liability for both the individual and the organization.

5b.

I should not help. Even though my friend claims the account is theirs, they cannot verify it — which means I have no way to confirm this. If I use password cracking tools on an account I don't own and haven't been authorized to access, I am committing unauthorized access regardless of who is asking or why.

The ethical principles guiding this decision are:

- Authorization — you must have explicit permission to access any system or account
- Do no harm — helping could facilitate account takeover of someone else's account
- Integrity — a security professional must not misuse their skills even for friends or personal favors

The right advice is to direct my friend to the official account recovery process provided by the email service provider.

5c.

1. Enforce a Strong Password Policy Require all users to create passwords of at least 12 characters including uppercase, lowercase, numbers, and symbols. As we saw in this lab, simple passwords like password123 were cracked within seconds using a basic dictionary attack. A strong password policy directly prevents this.

2. Use Strong, Salted Hashing Algorithms Store all passwords using modern algorithms like bcrypt or SHA-512 with unique salts for every user. In our lab, the MD5 hashes (11 1) were

cracked quickly because MD5 is fast and outdated. Bcrypt is intentionally slow, making brute force and dictionary attacks take exponentially longer.

3. Conduct Regular Authorized Vulnerability Assessments Schedule periodic security audits where authorized professionals use tools like JtR and Nmap to test the organization's own systems, exactly as practiced in this lab. This proactively identifies weak passwords, misconfigured files, and outdated software before an attacker does, allowing the organization to fix vulnerabilities before they are exploited.

.....